

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA5117

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20
Annexure A MOCK INTERVIEW

TOTAL MARKS: 20

Code of Conduct:

*I Harshini R N (192421175) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: Harshini R N

Annexure A MOCK INTERVIEW

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.
2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.
3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.
4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?
5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.
6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.
7. Evaluate the limitations of the SET protocol in current online payment systems.
8. Compare SET protocol with TLS-based payment security and justify which is more practical today.
9. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.
10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.
11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.
12. Compare viruses, worms, and Trojans based on propagation method and system impact.
13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.
14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.
15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.
16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.
18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.
19. Evaluate the differences between IDS and IPS in terms of response to detected threats.
20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

ANSWERS:

1. Weaknesses of SSL and why TLS is more secure

- SSL uses outdated cryptographic algorithms (MD5, SHA-1) vulnerable to attacks.
- Susceptible to downgrade attacks forcing weaker ciphers.
- No support for Perfect Forward Secrecy.
- TLS improves with stronger ciphers (AES, ChaCha20), secure hashing (SHA-256), and protections against downgrade attacks.

2. TLS handshake process and session key establishment

- Client Hello → client sends supported ciphers and random value.
- Server Hello → server responds with chosen cipher, random value, and certificate.
- Key Exchange → secure shared secret established (RSA, Diffie-Hellman, or ECDH).
- Session Key Derivation → both sides generate symmetric keys from shared secret + randoms.
- Finished Messages → encrypted confirmation ensures secure communication.

3. SSL vs TLS encryption mechanisms and improvements

- SSL: weaker ciphers (RC4, DES), weaker hashing (MD5, SHA-1).
- TLS: modern ciphers (AES, ChaCha20), stronger HMAC with SHA-256, support for forward secrecy.
- TLS adds protocol robustness, extensions, and downgrade protection.

4. Improper certificate validation in TLS

- Attacker can present forged/self-signed certificate.
- Leads to Man-in-the-Middle (MITM) attack.
- Sensitive data (passwords, credit cards) intercepted.
- Trust model breaks, communication compromised.

5. Role of digital certificates in SSL/TLS

- Certificates bind public keys to entities.
- Issued by trusted Certificate Authorities (CAs).
- Client verifies certificate validity and CA trust.
- Ensures authentication and prevents impersonation.

6. SET protocol protecting credit card transactions

- SET (Secure Electronic Transaction) encrypts cardholder data end-to-end.
- Uses dual signatures to protect both merchant and bank information.
- Ensures confidentiality, integrity, and authentication of transactions.
- Prevents merchants from seeing card details directly.

7. Limitations of SET protocol

- Complex implementation and overhead.
- Requires special software on client and merchant side.
- Not widely adopted due to usability issues.
- TLS-based solutions became simpler and more practical.

8. SET vs TLS-based payment security

- SET: strong but complex, limited adoption.
- TLS: widely supported, easier to implement, integrated with browsers.
- TLS is more practical today due to simplicity, scalability, and universal support.

9. Malware attack scenario differentiation

- **Virus:** attaches to files/programs, spreads when executed.
- **Worm:** self-replicates across networks without user action.
- **Trojan:** disguised as legitimate software, delivers malicious payload.
- Example: mass email spread → worm; infected file → virus; fake app → Trojan.

10. Mitigation techniques for worm attack

- Isolate infected systems immediately.
- Apply patches to vulnerable software.
- Use intrusion detection/prevention systems.
- Monitor network traffic for abnormal activity.
- Educate users on safe practices.

11. Impact of Trojan attacks

- Trojans steal confidential data (passwords, banking info).
- Can modify or delete files, harming integrity.
- Example: banking Trojan intercepts login credentials, leading to financial theft.

12. Viruses vs Worms vs Trojans

- **Virus:** needs host file, spreads via execution.
- **Worm:** self-replicates via networks.
- **Trojan:** disguised as legitimate software, relies on user installation.
- Impact: viruses damage files, worms disrupt networks, Trojans steal/confuse users.

13. Packet-filtering firewall working and limitations

- Inspects packets based on IP, port, protocol.
- Allows or blocks traffic based on rules.
- Limitations: cannot inspect payload, vulnerable to spoofing, lacks deep inspection.

14. Applying firewall rules

- Example: Block all traffic from IP 192.168.1.50.
- Allow HTTP (port 80) and HTTPS (port 443) traffic.
- Deny all other inbound connections.
- Rules ensure unauthorized access blocked while legitimate traffic flows.

15. Stateful vs stateless firewalls

- Stateless: checks packets individually, no context.
- Stateful: tracks connections, understands session state.
- Stateful more effective against spoofing and complex attacks.

16. Types of firewalls and recommendation

- Packet-filtering: basic, fast, but limited.
- Stateful inspection: tracks sessions, stronger security.
- Application-layer (proxy): inspects payload, prevents application-level attacks.
- Next-Gen Firewalls: combine deep inspection, IDS/IPS, advanced features.
- Recommendation: Next-Gen Firewall for enterprise networks.

17. IDS detection techniques

- Signature-based: matches known attack patterns.
- Anomaly-based: detects deviations from normal behavior.
- Combination improves detection accuracy.

18. IDS/IPS against DDoS

- IDS detects abnormal traffic patterns.
- IPS blocks malicious traffic in real-time.
- Rate limiting, traffic filtering, and blacklisting mitigate DDoS impact.

19. IDS vs IPS differences

- IDS: passive, alerts administrators, no direct blocking.

- IPS: active, blocks malicious traffic immediately.
- IDS = detection, IPS = prevention.

20. Reducing false positives in IDS

- Use hybrid detection (signature + anomaly).
- Regularly update signatures.
- Tune anomaly thresholds carefully.
- Employ machine learning for adaptive detection.